Bilgi Güvenliği ve BT Kullanım Politikaları

RAG eğitimi için hazırlanmış örnek kurumsal doküman

1. Giriş

Bu doküman, şirket bilgi varlıklarının güvenliğini korumak ve kurumsal bilgi teknolojileri kaynaklarının doğru kullanımını sağlamak amacıyla hazırlanmıştır. Tüm çalışanlar, eriştikleri veri ve sistemlerin güvenliğinden kendi yetkileri ölçüsünde sorumludur.

1.1 Amaç

Amaç; hesap güvenliği, cihaz kullanımı, uzaktan erişim, veri paylaşımı ve güvenlik olaylarının bildirilmesi için ortak bir çalışma standardı oluşturmaktır.

1.2 Kapsam

Politika; şirket bilgisayarları, mobil cihazlar, e-posta hesapları, bulut servisleri, VPN erişimi ve kurum içi uygulamalara erişen tüm kullanıcıları kapsar.

2. Hesap ve Erişim Güvenliği

Kullanıcı hesapları kişiye özeldir ve başka kişilerle paylaşılmaz. Erişim yetkileri, çalışanın görevini yerine getirmesi için gerekli minimum yetki prensibine göre tanımlanır.

2.1 Parola Politikası

Kurumsal hesaplarda tahmin edilmesi zor ve benzersiz parolalar kullanılmalıdır. Aynı parola kişisel servislerde veya farklı kurumsal sistemlerde tekrar kullanılmamalıdır.

- Parolalar e-posta, mesaj veya doküman içinde açık biçimde paylaşılmaz.
- Şüpheli hesap hareketinde parola derhal değiştirilir.
- Parola yöneticisi kullanılacaksa kurum tarafından onaylanmış çözüm tercih edilir.

2.2 Çok Faktörlü Kimlik Doğrulama

MFA destekleyen kritik kurumsal sistemlerde çok faktörlü kimlik doğrulama etkinleştirilir. Kullanıcı, kendisinin başlatmadığı doğrulama bildirimlerini onaylamamalıdır.

2.3 Yetkilendirme ve Erişim Kaldırma

Erişim yetkileri görev değişikliklerinde yeniden değerlendirilir. İşten ayrılma veya rol değişimi durumunda artık gerekli olmayan erişimler bilgi teknolojileri birimi tarafından kaldırılır.

3. Kurumsal Cihaz Kullanımı

Şirket cihazları iş amaçlı kullanım için tahsis edilir. Cihazların güvenlik ayarları kullanıcı tarafından devre dışı bırakılmamalı ve şirketin belirlediği yazılım standartlarına uyulmalıdır.

3.1 Dizüstü Bilgisayar ve Mobil Cihazlar

Kurumsal cihazlarda ekran kilidi etkin olmalı ve cihaz gözetimsiz bırakıldığında kilitlenmelidir. Kayıp veya çalınma durumunda bilgi teknolojileri birimine derhal bildirim yapılır.

3.2 Yazılım Kurulumu

Lisansı belirsiz, kaynağı bilinmeyen veya güvenlik riski taşıyan yazılımlar kurulmamalıdır. İş için gerekli yeni yazılımlar bilgi teknolojileri biriminin onayıyla yüklenir.

3.3 Taşınabilir Bellek ve Harici Diskler

USB bellek veya harici disk gibi taşınabilir ortamlar yalnızca ihtiyaç halinde ve kurum politikasına uygun biçimde kullanılmalıdır. Hassas veri taşıyan cihazlarda şifreleme uygulanmalıdır.

4. Ağ ve Uzaktan Erişim

Şirket sistemlerine uzaktan erişimde güvenli bağlantı yöntemleri kullanılmalıdır. Açık veya güvenilmeyen ağlardan doğrudan kritik sistemlere bağlanılmamalıdır.

4.1 VPN Kullanımı

Kurum içi kaynaklara uzaktan erişim gerektiğinde şirket tarafından sağlanan VPN kullanılmalıdır. VPN hesapları kişiye özeldir ve bağlantı bilgileri başka kullanıcılarla paylaşılmaz.

4.2 Kablosuz Ağ Güvenliği

Halka açık Wi-Fi ağları üzerinde hassas işlemler yapılmamalıdır. Zorunlu kullanım durumunda VPN bağlantısı kurulmadan kurumsal sistemlere erişilmemelidir.

4.3 Uzaktan Destek ve Ekran Paylaşımı

Uzaktan destek oturumları yalnızca yetkili personelle gerçekleştirilir. Ekran paylaşımı sırasında hassas bilgi içeren uygulamalar kapatılmalı veya görünürlük sınırlandırılmalıdır.

5. Veri Sınıflandırma ve Paylaşım

Kurumsal veriler hassasiyet seviyesine göre sınıflandırılır. Bilginin paylaşım şekli, saklama yeri ve erişim yetkisi bu sınıflandırmaya göre belirlenir.

5.1 Veri Sınıfları

Genel bilgiler kamuya açık olabilir. Kurum içi bilgiler yalnızca çalışanlarla paylaşılır. Gizli bilgiler ise yalnızca işi gereği erişmesi gereken yetkili kullanıcılarla sınırlandırılır.

5.2 Dosya Paylaşımı

Kurumsal dosyalar onaylı depolama ve paylaşım servislerinde tutulmalıdır. Kişisel bulut hesapları veya yetkisiz dosya aktarım servisleri hassas kurumsal veriler için kullanılmamalıdır.

5.3 E-posta ile Bilgi Paylaşımı

E-posta gönderilmeden önce alıcı adresleri ve ekler kontrol edilmelidir. Gizli veya kişisel veri içeren dosyaların paylaşımında kurumun belirlediği güvenlik yöntemleri uygulanmalıdır.

6. Güvenlik Olaylarının Bildirilmesi

Şüpheli e-posta, hesap ele geçirilmesi, cihaz kaybı veya yetkisiz veri erişimi gibi olaylar gecikmeden bilgi güvenliği veya bilgi teknolojileri ekibine bildirilmelidir.

6.1 Oltalama ve Şüpheli E-postalar

Kullanıcıdan parola isteyen, acil işlem baskısı oluşturan veya bilinmeyen bağlantılar içeren e-postalar şüpheli kabul edilmelidir. Bağlantıya tıklamadan veya eki açmadan önce gönderici doğrulanmalıdır.

6.2 Kayıp veya Çalınan Cihaz

Kurumsal cihazın kaybolması veya çalınması halinde olay hemen bildirilmelidir. Bilgi teknolojileri ekibi gerekli durumlarda uzaktan erişimi kapatabilir veya cihaz üzerinde güvenlik işlemleri başlatabilir.

6.3 Olay Bildirim Süreci

Bildirimde olayın zamanı, etkilenen cihaz veya hesap, görülen belirtiler ve kullanıcının yaptığı işlemler mümkün olduğunca açık şekilde paylaşılmalıdır. Kullanıcı, olay incelemesi tamamlanana kadar ilgili kayıtları silmemelidir.